

Manual 10 - Implementação Controlada do NIST RMF e SP 800-53

CANDIDATO CONTROLADO PARA QA DE PUBLICACAO

Revisão da fonte controlada: 9c420201ad6822c594e74c7f7508e00b53472f4c | Idioma: pt-BR | limites de autorização RMF e de decisão humana mantidos.

Limite de asseguarção: Este manual operacionaliza conceitos do NIST RMF e SP 800-53, mas não autoriza um sistema, não cria certificação NIST, não comprova efetividade de controles, não estabelece conformidade legal nem substitui uma autoridade de autorização responsável ou um avaliador competente. Tailoring, avaliação, autorização, exceções, risco residual e decisões materiais exigem julgamento humano responsável.

Caminhos de implementação

Manual 10 — Caminhos de implementação

Rascunho controlado assistido por máquina (pt-BR). A edição em inglês continua sendo a fonte controlada. Esta localização não constitui aprovação semântica ou terminológica humana e permanece sujeita à etapa de revisão humana antes da publicação.

Essencial

Use para sistemas menores ou de escopo limitado. Expectativas mínimas de implementação:

- limite do sistema, proprietário, contexto de missão/negócio e funções responsáveis definidos;
- responsáveis por cada etapa do RMF e pontos de decisão documentados;
- categorização apropriada e seleção inicial da linha de base de controles;
- justificativa documentada de tailoring;
- identificação clara de controles comuns, específicos do sistema e híbridos;
- evidência de implementação para os controles selecionados;
- planejamento de avaliação baseado em risco e acompanhamento de achados;
- decisão explícita de autorização pela autoridade humana responsável;
- cadência de monitoramento contínuo, exceções e acompanhamento de POA&M.

Estruturado

Use para múltiplos sistemas, serviços compartilhados, ambientes regulados ou risco organizacional material. Adicione:

- estratégia de risco em nível organizacional vinculada às decisões em nível de sistema;
- governança reutilizável de controles comuns e evidência de herança;
- planejamento de segurança, privacidade e C-SCRM do sistema alinhado ao SP 800-18 Rev. 2;
- registros formais de tailoring de controles e overlays quando apropriado;
- evidência estruturada de avaliação alinhada ao SP 800-53A;
- evidência legível por máquina e OSCAL quando operacionalmente útil;
- gestão formal do pacote de autorização;
- monitoramento contínuo recorrente e gatilhos de reavaliação;
- governança de exceções, aceitação de risco e POA&M com expiração e responsabilidade por remediação.

Aprimorado

Use para ambientes de alto impacto, missão crítica, escala empresarial, alta regulação ou interconexão. Adicione:

- agregação de risco entre sistemas e relatórios de risco corporativo;
- governança rigorosa de provedores de controles comuns e validação de herança;
- avaliação independente e testes técnicos especializados quando o risco justificar;
- coleta automatizada de evidências com controles de proveniência;
- artefatos de sistema/controle/avaliação apoiados por OSCAL quando viável;
- monitoramento contínuo de controles vinculado a mudanças materiais e ao status de autorização;

- critérios formais de autorização contínua quando adotados pela organização;
- aceitação executiva de risco residual material;
- resiliência, cadeia de suprimentos, privacidade e risco de dependências integrados às decisões de autorização.

Rota de evidência RMF

Gráfico de memória do Manual 10 1

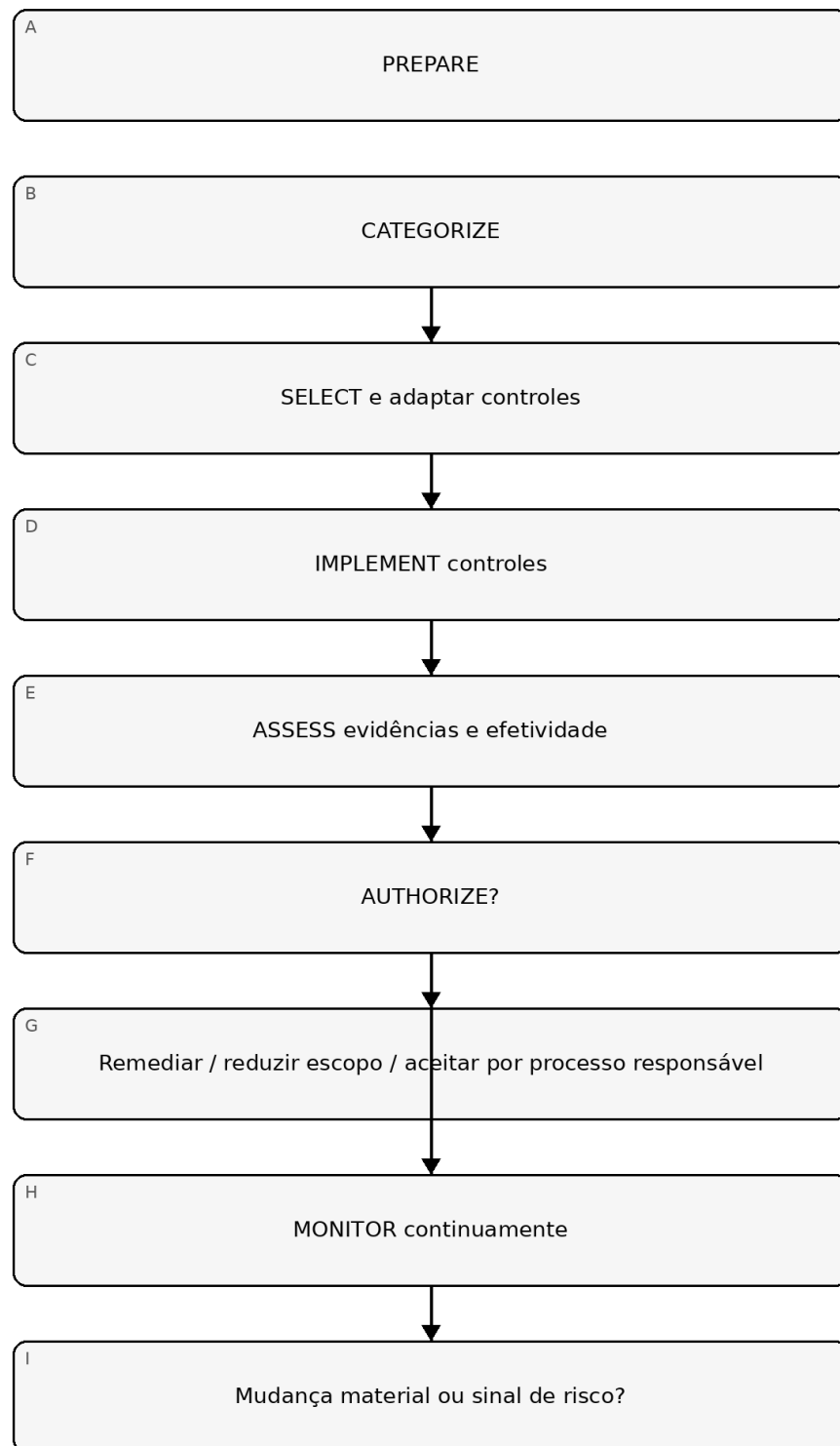


Figura 1. Gráfico de memória de implementação RMF

Explicação acessível: O RMF é um ciclo contínuo de evidência e decisão. Uma decisão negativa de autorização devolve o trabalho para remediação ou tratamento responsável do risco, em vez de criar aprovação automática. O monitoramento devolve mudanças materiais à preparação e à reavaliação.

Cadeia de evidência de controles

Gráfico de memória do Manual 10 2

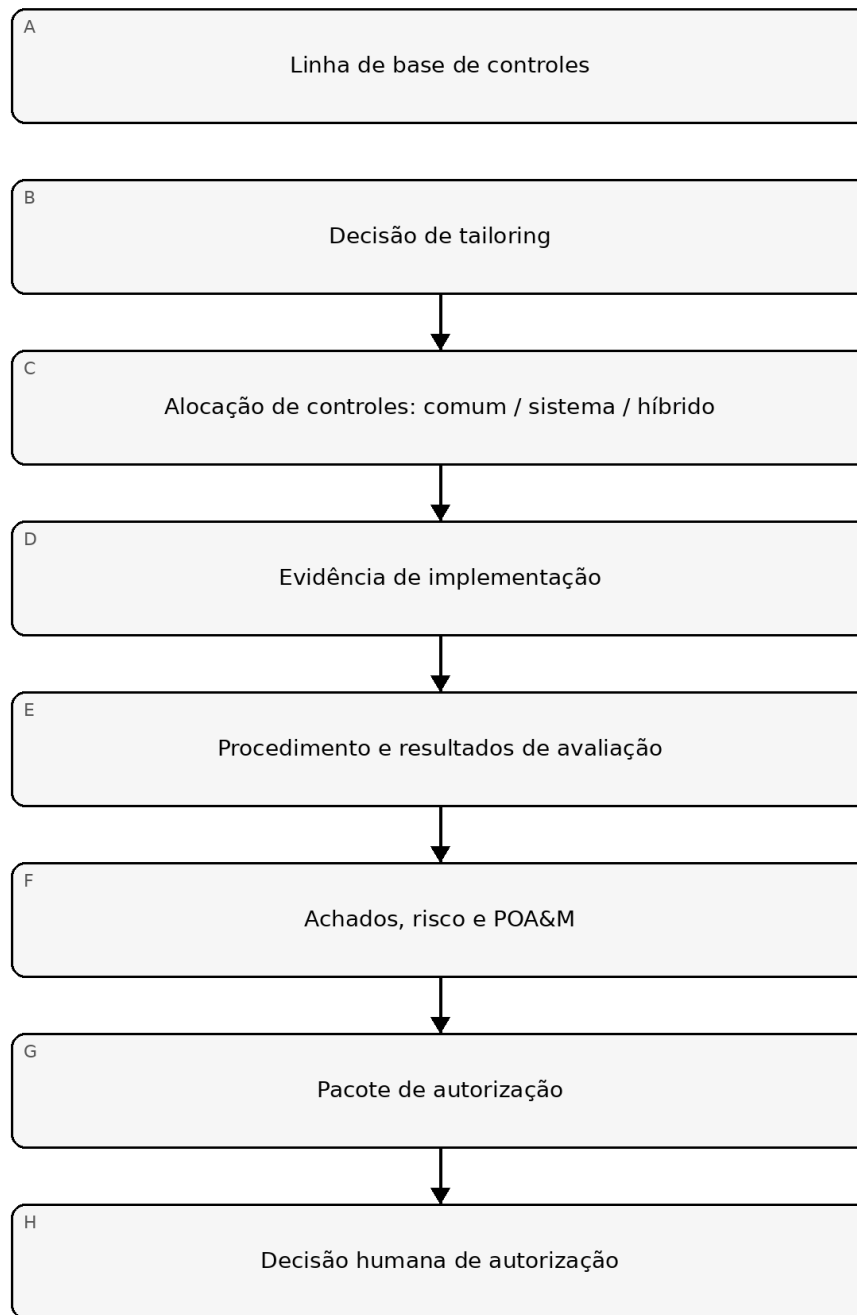


Figura 2. Gráfico de memória de implementação RMF

Explicação acessível: A evidência deve conectar seleção da linha de base, tailoring, alocação, implementação, avaliação, achados, remediação e a decisão final de autorização responsável. Nenhuma lista de verificação ou fluxo automatizado substitui essa cadeia.

Cadeia de planejamento e evidência legível por máquina

Gráfico de memória do Manual 10 3

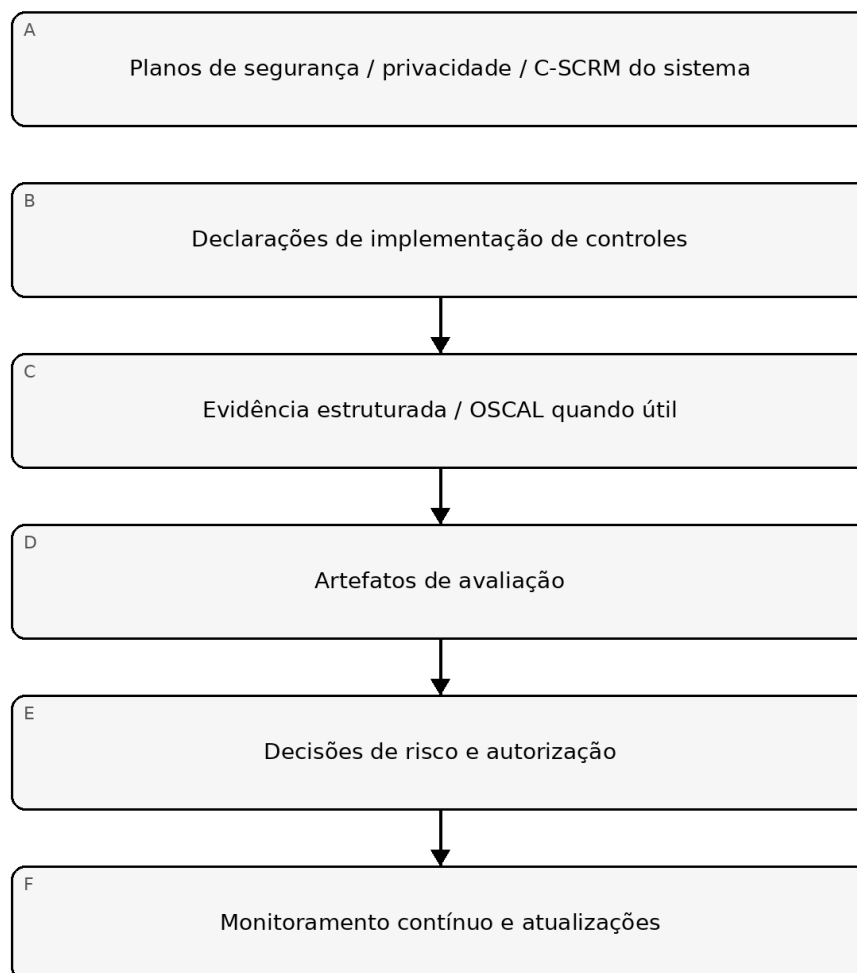


Figura 3. Gráfico de memória de implementação RMF

Explicação acessível: Os planos do sistema e as declarações de implementação devem permanecer conectados às evidências de avaliação, decisões de risco, autorização e monitoramento. Formatos legíveis por máquina podem melhorar a rastreabilidade, mas não criam asseguração por si mesmos.

Limite de controle

O manual é baseado em risco, adaptável e baseado em evidências. Ele não deve apresentar controles do SP 800-53 como universalmente obrigatórios fora de seu contexto de governança aplicável, não deve tratar a linha de base como uma lista de verificação sem tailoring e não deve implicar que passar no QA do repositório ou em um teste automatizado de controles constitui autorização, certificação ou aceitação de risco.

Manual controlado de 32 capítulos

Capítulo 01 — Propósito do RMF e arquitetura de decisão

Use o RMF como ciclo operacional de gestão de riscos que conecta objetivos de missão, contexto do sistema, riscos de segurança e privacidade, implementação de controles, evidência de avaliação, decisões de autorização e monitoramento contínuo. Evite tratá-lo como exercício documental pontual.

Defina papéis responsáveis, limites do sistema, autoridades de decisão, caminhos de escalonamento, expectativas de evidência e a relação entre decisões de risco organizacionais e do sistema.

Capítulo 02 — PREPARAR no nível organizacional

Estabeleça premissas de risco, governança, tolerância ao risco, estratégia de controles comuns, expectativas de cadeia de suprimentos, arquitetura corporativa, serviços compartilhados, estratégia de avaliação e de monitoramento antes da avaliação de sistemas individuais.

A evidência deve mostrar responsáveis, critérios de risco aprovados, premissas de dependência, provedores de controles comuns, evidência reutilizável e riscos corporativos não resolvidos.

Capítulo 03 — PREPARAR no nível do sistema

Defina missão, dono do negócio, dono do sistema, limite de autorização, ambiente operacional, usuários, dados, interfaces, dependências, fornecedores, serviços herdados e ciclo de vida esperado.

Documente premissas e desconhecidos explicitamente. Incerteza de limites, propriedade ambígua ou dependências ausentes devem permanecer visíveis como risco.

Capítulo 04 — Responsabilidade de partes interessadas e papéis

Identifique autoridade autorizadora, função executiva de risco, dono do sistema, dono da informação, provedores de controles, avaliadores, responsáveis por segurança/privacidade, arquitetos, engenheiros, operações, jurídico, privacidade, cadeia de suprimentos e representantes de negócio necessários.

Separe suficientemente implementação, avaliação e autorização para preservar desafio independente e responsabilidade decisória.

Capítulo 05 — Caracterização de informação e sistema

Caracterize tipos de informação, finalidade de processamento, usuários, tecnologias, localizações, interfaces, fluxos de dados, conexões externas, dependências de nuvem ou serviços compartilhados, tecnologia operacional quando aplicável e relações de cadeia de suprimentos.

A caracterização deve apoiar análise de segurança e privacidade e ser mantida conforme o sistema muda.

Capítulo 06 — CATEGORIZAR impacto de segurança

Categorize o sistema usando métodos aplicáveis de análise de impacto e política organizacional. Registre a justificativa das determinações de confidencialidade, integridade e disponibilidade, incluindo consequências de missão e dependências.

A categoria é uma entrada decisória, não substitui análise de ameaças, privacidade ou risco de negócio.

Capítulo 07 — Privacidade e considerações adicionais de impacto

Integre risco de privacidade, obrigações legais, sensibilidade de dados, impactos de missão, segurança, requisitos contratuais, exposição de cadeia de suprimentos e outros fatores que possam exigir proteções adicionais.

Documente onde análises separadas de privacidade, risco ou revisão especializada alteram a linha de base de controles ou o pacote de autorização.

Capítulo 08 — Gate fail-closed de PREPARAR/CATEGORIZAR

Não prossiga como se o sistema estivesse pronto para seleção de controles quando o limite de autorização não está resolvido, falta propriedade responsável, as determinações de impacto não são sustentadas, dependências críticas são desconhecidas ou premissas organizacionais contradizem a realidade.

Verificações automatizadas podem validar registros e relações requeridos, mas categorização, escopo e responsabilidade exigem julgamento humano competente.

Status da localização: rascunho controlado; revisão semântica humana obrigatória antes de aprovação ou publicação.

Capítulo 09 — SELECIONAR a linha de base inicial de controles

Escolha uma linha de base inicial apropriada usando política organizacional e orientação NIST aplicável. Registre fonte da linha de base, contexto de impacto, premissas, controles herdados, controles comuns, overlays e outros requisitos que influenciem o conjunto inicial.

A linha de base inicial é o ponto estruturado para tailoring e refinamento baseado em risco, não o conjunto final de controles.

Capítulo 10 — Decisões de tailoring e escopo

Adapte controles de forma transparente conforme aplicabilidade, tecnologia, missão, risco, ambiente, salvaguardas compensatórias, obrigações legais ou contratuais e tolerância ao risco.

Cada decisão material deve registrar justificativa, autoridade, controles afetados, premissas, risco residual, dependências e condições de revisão. Tailoring não deve virar exclusão não documentada de controles.

Capítulo 11 — Controles comuns, específicos e híbridos

Classifique controles conforme onde residem responsabilidade e implementação. Identifique provedores de controles comuns, partes herdadas, responsabilidades específicas, limites híbridos e responsáveis pela evidência.

Afirmações de herança devem identificar o provedor real, escopo de implementação, fonte de evidência, aplicabilidade, status e parâmetros ou responsabilidades residuais do sistema.

Capítulo 12 — Parametrização e declarações de implementação

Traduza controles selecionados em declarações específicas do sistema, parâmetros, papéis, tecnologias, procedimentos e expectativas de evidência. Evite repetir objetivos genéricos sem explicar como o sistema os atende.

Declarações devem ser testáveis, atuais, versionadas e rastreáveis a arquiteturas, configurações, procedimentos, logs, tickets, contratos ou outra evidência.

Capítulo 13 — Planejamento de segurança, privacidade e C-SCRM

Mantenha documentação que explique contexto do sistema, controles selecionados, abordagem de implementação, privacidade, dependências de cadeia de suprimentos, premissas de risco, responsabilidades e fontes de evidência.

Use orientação NIST atual para estruturar registros vivos, não documentos estáticos produzidos apenas para eventos de autorização.

Capítulo 14 — IMPLEMENTAR controles no ambiente operacional

Implemente controles selecionados em tecnologia, processos, pessoas, instalações, contratos e fornecedores conforme aplicável. Configuração, procedimentos, limites de acesso, monitoramento, treinamento, recuperação e coleta de evidência devem refletir o desenho aprovado.

A conclusão da implementação deve ser baseada em evidência, não apenas em status de tarefa.

Capítulo 15 — Evidência de implementação e procedência

Para cada controle material, preserve evidência suficiente do que foi implementado, onde, por quem, quando, sob qual configuração ou versão e com quais limitações.

A evidência deve ser relevante, atual, atribuível, resistente a adulteração quando apropriado e vinculada ao escopo exato. Evidência gerada por máquinas exige procedência e interpretação humana quando houver julgamento.

Capítulo 16 — Gate fail-closed de SELECIONAR/IMPLEMENTAR

Não trate o conjunto de controles como pronto quando falta justificativa de tailoring, a responsabilidade por controles herdados é ambígua, declarações não são testáveis, parâmetros críticos estão indefinidos ou a evidência não pode ser rastreada ao sistema real.

Automação pode apoiar mapeamento e coleta de evidência, mas não estabelecer sozinha aplicabilidade, implementação efetiva ou risco residual aceitável.

Status da localização: rascunho controlado; revisão semântica humana obrigatória antes de aprovação ou publicação.

Capítulo 17 — Planejamento da avaliação

Defina escopo, objetivos, controles selecionados, procedimentos, fontes de evidência, expectativas de independência, amostragem, ambientes de teste, participantes, cronograma e limitações antes do trabalho de campo.

O plano deve distinguir questões de desenho, implementação e efetividade operacional e identificar onde controles herdados ou comuns exigem evidência separada.

Capítulo 18 — Suficiência e qualidade da evidência

Avalie relevância, confiabilidade, atualidade, completude, escopo, procedência e aplicabilidade da evidência. Um artefato válido pode ser insuficiente se cobrir outro ambiente, período, serviço ou limite de responsabilidade.

Documento premissas, evidência indisponível, evidência contraditória e incerteza, em vez de ocultá-las por trás de rótulos de aprovado/reprovado.

Capítulo 19 — Procedimentos e testes de avaliação

Use exame, entrevista e testes apropriados para determinar se os controles estão implementados corretamente, operam conforme pretendido e produzem o resultado esperado. Adapte procedimentos à tecnologia, risco, contexto e evidência disponível.

Testes automatizados podem melhorar cobertura e repetibilidade, mas o julgamento do avaliador continua necessário para interpretação, escopo, limitações e significância.

Capítulo 20 — Achados, fraquezas e severidade

Registre achados com controles afetados, escopo, evidência, condição, estado esperado, consequência de risco, causa raiz quando conhecida, justificativa de severidade, responsável, caminho de remediação e requisitos de validação.

Não reduza achados a exceções de checklist sem explicar risco material ou impacto de implementação.

Capítulo 21 — Relatório de avaliação e pacote de risco

Prepare um pacote que diferencie escopo testado, procedimentos executados, evidência revisada, achados, limitações, dependências de controles herdados, perguntas em aberto e conclusões do avaliador.

O pacote deve apoiar decisões de risco sem exagerar a asseguarção além da evidência coletada.

Capítulo 22 — Pacote de autorização

Reúna planos do sistema, evidência de implementação, resultados de avaliação, análises de risco, itens de POA&M, exceções, dependências de controles comuns, declarações de risco residual e restrições operacionais relevantes.

O pacote deve expor risco aberto e incerteza material, não otimizar por uma aparência limpa.

Capítulo 23 — Decisão de autorização e condições

A autoridade autorizadora ou equivalente decide se o risco residual é aceitável para missão, escopo, ambiente e período definidos. A decisão pode autorizar, autorizar com condições, exigir remediação, restringir operação, adiar ou negar autorização.

Registre autoridade, data, escopo, evidência considerada, riscos materiais, condições, expiração ou gatilhos de revisão e acompanhamento exigido.

Capítulo 24 — Gate fail-closed de AVALIAR/AUTORIZAR

Não trate um sistema como pronto para autorização quando o escopo de avaliação é materialmente incompleto, achados significativos não são sustentados ou resolvidos, a qualidade da evidência é inadequada, a responsabilidade de autorização é incerta ou o risco residual está oculto do decisor.

Automação pode apoiar avaliação e montagem do pacote, mas não substitui julgamento competente nem a decisão humana responsável de autorização.

Status da localização: rascunho controlado; revisão semântica humana obrigatória antes de aprovação ou publicação.

Capítulo 25 — Estratégia de monitoramento contínuo

Defina quais controles, riscos, configurações, vulnerabilidades, eventos, dependências, fornecedores, fontes de evidência e mudanças do sistema exigem monitoramento contínuo. Estabeleça frequência, gatilhos, responsáveis, retenção, relatórios, limiares e escalonamento.

O monitoramento deve priorizar risco e mudança, não apenas coletar métricas recorrentes.

Capítulo 26 — Impacto de mudanças e controle de configuração

Avalie mudanças materiais de sistema, arquitetura, software, dados, identidades, fornecedores, nuvem, interfaces, missão e controles quanto ao impacto em controles selecionados, evidência, conclusões de avaliação e condições de autorização.

Mudanças que invalidem evidência ou premissas de risco devem reabrir a revisão afetada.

Capítulo 27 — Governança de POA&M e remediação

Gerencie Planos de Ação e Marcos como registros responsáveis de tratamento de risco. Cada item deve identificar fraqueza, sistema ou controle afetado, significância do risco, responsável, ação, marcos, datas, controles provisórios, dependências, evidência requerida e escalonamento.

Extensões repetidas de prazo sem análise de risco atualizada e aprovação não devem ser tratadas como remediação efetiva.

Capítulo 28 — Avaliação contínua e atualização de evidência

Atualize evidência conforme risco, volatilidade de controles, resultados de monitoramento, incidentes, mudanças, expiração e condições de autorização. Reavalie controles quando a evidência ficar obsoleta, o escopo mudar, a implementação divergir ou surgir nova informação de risco.

Monitoramento contínuo não elimina a necessidade de avaliação humana direcionada e desafio independente.

Capítulo 29 — Monitoramento de controles comuns e risco herdado

Acompanhe provedores de controles comuns e controles herdados durante o período de autorização. Monitore mudanças do provedor, interrupções, achados, mudanças de escopo, resultados e atualidade da evidência que possam alterar o risco dos sistemas dependentes.

Um sistema não deve continuar creditando proteção herdada quando a evidência do provedor já não sustenta essa afirmação.

Capítulo 30 — OSCAL e evidência legível por máquina

Use OSCAL ou outros formatos legíveis por máquina quando apropriado para melhorar rastreabilidade, intercâmbio, validação, automação e procedência em catálogos, perfis, planos, avaliações e evidência relacionada.

Registros devem preservar identidade da fonte, versão, escopo, autoria, timestamps, limitações e limites de decisão humana. Automação melhora consistência, mas não cria autoridade de autorização.

Capítulo 31 — Suporte à autorização contínua e decisões de risco

Use monitoramento e evidência atualizada para apoiar decisões contínuas, incluindo continuidade de operação, condições, remediação, restrições, reavaliação ou reautorização quando exigidas por política ou mudança material.

Autorização contínua deve significar disponibilidade contínua de evidência de qualidade e governança, não aprovação automática por ferramentas.

Capítulo 32 — Liberação do manual e limite de asseguração

O Manual 10 só é encerrado quando verificação de fontes, mestre inglês de 32 capítulos, revisão técnica/editorial/de mapeamento, localização es-419 e pt-BR com revisão semântica humana, acessibilidade, QA DOCX/PDF, segurança do repositório/workflows, manifesto/checksums/procedência, reconciliação exact-head e Aprovação Humana Final de Liberação estiverem completas para o mesmo candidato exato.

A conclusão não autoriza nenhum sistema real, não certifica conformidade e não elimina risco residual.

Status da localização: rascunho controlado; revisão semântica humana obrigatória antes de aprovação ou publicação.